FICHE 8 - PROTÉGER LE RÉSEAU INFORMATIQUE

Autoriser uniquement les fonctions réseau nécessaires aux traitements mis en œuvre.

Le réseau interne interconnecte l'ensemble des composants des systèmes d'information d'un organisme et dispose souvent de points de connexion avec l'extérieur. Il s'agit tout autant d'un point d'entrée que d'un support de propagation des attaques. Il est donc primordial de sécuriser le réseau interne.

Les précautions élémentaires

- **Limiter les accès Internet** en bloquant les services non nécessaires (ex. : VoIP, pair à pair).
- **Gérer les réseaux Wi-Fi.** Ils doivent utiliser un chiffrement à l'état de l'art (WPA3 ou WPA2 en respectant les recommandations de l'ANSSI sur la configuration de ce dernier[28]) et les réseaux ouverts aux invités doivent être séparés du réseau interne.
- **Imposer un VPN pour l'accès à distance** avec, si possible, une authentification robuste de l'utilisateur (ex. : carte à puce, mot de passe à usage unique basé sur le temps (TOTP)).
- **S'assurer qu'aucune interface d'administration n'est accessible directement depuis Internet.** Les opérations d'administration et de maintenance doivent tout particulièrement s'effectuer à travers un VPN.
- Privilégier le protocole SSH (correctement configuré) ou un accès physique direct pour l'administration des équipements réseau.
- **Limiter les flux réseau au strict nécessaire** en filtrant les flux entrants/sortants sur les équipements (ex. : pare-feux, serveurs proxy). Par exemple, si un serveur web utilise obligatoirement HTTPS, il faut autoriser uniquement les flux entrants sur cette machine sur le port 443 et bloquer tous les autres ports.
- **Cloisonner le réseau** pour réduire l'impact en cas de compromission. On peut au minimum **distinguer un réseau interne sur lequel aucune connexion venant d'Internet n'est autorisée et un réseau DMZ** (« *demilitarized zone* ») **accessible depuis Internet**, en les séparant par des passerelles (« *gateway* »).

Ce qu'il ne faut pas faire

- Utiliser le protocole Telnet pour la connexion aux équipements actifs du réseau (ex. : pare-feux, routeurs, passerelles).
- Mettre à disposition des utilisateurs un accès Internet non filtré.
- Mettre en place un réseau Wi-Fi utilisant un chiffrement WEP.

28 « Sécuriser les accès Wi-Fi », cyber.gouv.fr